프로젝트 기획서

AI 기반 업로드 파일 악성코드 사전 탐지·차단 시스템 구축

업로드된 파일을 배포 전에 검사해 알려진 악성은 즉시 차단하고,
의심 파일만 격리된 가상 환경에서 실행해 확인한 뒤 자동으로 판정·조치합니다.

정적 분석 | 동적 분석(CAPEv2) | Decision Engine | PE · MS Office · HWP/HWPX | 업로드 저장소 · CDN

문서 구분	프로젝트 기획서
버전	04
작성일	2026. 11. 10.
팀원	김윤준, 구명회, 남유진, 이인애, 백선병

목 차

1. 프로젝트 정의 3
2. 최종 목표 5
3. 서비스 범위 및 전략 6
4. 전체 아키텍처 7
5. 정적 분석 상세 9
6. 재귀 분석과 한도 14
7. 동적 분석 상세 (CAPEv2) 15
8. Decision Engine — 최종 판정 19
9. 데이터 및 평가 22
10. 기술 인프라 및 비용 26
11. 실 서비스 적용 및 대응 방안 29
12. 추진 일정 2026. 11. 1. ~ 11. 30. 31
13. 리스크 및 한계 33
14. 결정 필요 항목 34
15. 부록 용어 · 참고 자료 35

1. 프로젝트 정의

프로젝트명 **AI 기반 업로드 파일 악성코드 사전 탐지·차단 시스템 구축**

1.1 추진 배경: AI가 악성코드 생산의 문턱을 없애다

과거에는 악성코드를 만들려면 프로그래밍 언어, 운영체제 내부 구조, 네트워크 프로토콜에 대한 상당한 이해가 필요했습니다. AI는 이 장벽을 사실상 제거했습니다.

Arctic Wolf Labs가 2025년 2월부터 1년간 AI 관련 탐지 규칙으로 수집한 악성코드 샘플 22,000여 개를 분석한 결과, AI는 악성코드 제작을 더 빠르고 광범위하게 만들었고, **도구를 만들 능력이 없던 공격자에게까지 접근 가능하게** 만들었습니다. 전체 샘플 중 1.4%만이 알려진 표적 공격, 위협 행위자, 금전 목적 범죄 조직과 연결되었고, 나머지 대부분은 신원이 확인되지 않은 일반 공격자였습니다.

즉, **공격자의 저변이 폭발적으로 넓어졌다는 사실**을 알 수 있습니다.

출처: Arctic Wolf Labs, "The AI Malware Surge: Behavior, Attribution, and Defensive Readiness", 2026-03-24

1.2 필요성: 정적 분석의 한계와 추가 검사의 필요성

정적 분석은 **파일을 실행하지 않고** 해시, 시그니처, 파일 구조, 머신러닝 특징 등을 분석하여 악성 여부를 판단합니다. 대량의 파일을 빠르게 검사하는 데 효과적이지만, **신종·변종 악성코드나 난독화된 파일에서는 탐지에 한계**가 있습니다.

ISSTA Companion 2025에서 발표된 He 외 연구에서는 LLM으로 생성한 적대적 악성코드가 VirusTotal의 상용 백신 12개 엔진에서 **평균 89.92%의 회피율**을 기록했습니다. 이는 특정 실험 환경에서 **AI 기반 코드 변형이 기존 탐지 성능을 크게 저하시킬 수 있음**을 보여줍니다.

2026년 2월 Google 위협 인텔리전스 그룹(GTIG)이 공개한 HONESTCUE는 **Gemini API를 이용해 후속 실행에 필요한 코드를 생성하고 메모리에서 실행**하는 방식을 사용했습니다.

이처럼 일부 악성 기능이 최초 파일에 직접 포함되지 않으면 **정적 분석만으로 전체 행동을 파악하기 어려울 수 있습니다.**

따라서 정적 분석의 빠른 처리 능력을 활용하면서도, 정적 정보만으로 판단하기 어려운 파일에 대해서는 **실행 행동을 확인하는 추가 검사가 필요합니다.**

출처: He 외, "From Large Language Models to Adversarial Malware: How far are we", ISSTA Companion '25 · Google GTIG, "Distillation, Experimentation, and (Continued) Integration of AI for Adversarial Use", 2026-02

1.3 대응: 고객 맞춤형 선택적 동적 분석 파이프라인

정적 분석만으로 판단하기 어려운 파일은 격리된 환경에서 **실행 행동을 관찰하는 동적 분석으로 보완**할 수 있습니다. 그러나 동적 분석은 정적 분석보다 처리 시간과 자원 소모가 크기 때문에, **모든 업로드 파일에 적용하면 운영 비용과 배포 지연이 증가**합니다.

이에 본 프로젝트는 **고객이 원하는 정밀 검사 수준과 비용 제약에 맞춰 동적 분석 대상을 조절하는 계층적 파이프라인**을 제공합니다. 정적 분석으로 알려진 악성을 차단하고 나머지 파일의 위험도를 평가한 뒤, 고객이 설정한 검사 정책에 따라 **위험도가 높은 파일부터 동적 분석 대상으로 선별**합니다.

선별된 파일은 CAPEv2의 격리된 Windows 환경에서 실행하여 **프로세스 생성, 파일 변경, 네트워크 통신 등의 행동**을 분석합니다. 최종적으로 Decision Engine이 **정적 탐지 근거와 동적 행동 결과를 종합해 차단·배포·보류를 결정**합니다. 분석이 실패하거나 판단 근거가 부족한 파일은 **정상으로 처리하지 않고 보류**합니다.

고객은 필요한 정밀 검사 수준에 따라 **동적 분석에 투입하는 자원을 조절**할 수 있으며, 서비스 운영자는 **제한된 분석 자원을 위험도가 높은 파일에 집중**할 수 있습니다. 초기에는 **형식별 정상 파일의 동적 분석 전송률 2~5%**를 기준으로 정책을 구성합니다.

단계	하는 일	비용
정적 선별	알려진 악성은 즉시 차단하고, 나머지는 점수를 매겨 정상 파일의 2~5%만 동적 분석으로 보냄	실측 파일당 약 1초
동적 확인	CAPEv2의 Windows 10 게스트에서 파일을 열거나 실행해 프로세스·파일·네트워크 행동을 기록	CAPEv2 기본 분석 시간 200초 + 여유 60초
자동 판정과 조치	Decision Engine이 정적 근거와 동적 결과를 합쳐 판정하고, 저장소 태그·폴더 이동·CDN 삭제 요청·알림을 수행	수 초
자동화	동적 분석으로 확정된 악성의 해시와 닮음 값을 1차 목록에 더해 다음부터 즉시 차단 머신러닝 모델을 재학습해 성능이 개선되면 해당 모델로 교체	자동

출처: 파일당 시간은 미니 프로젝트 실측, 동적 분석 시간은 CAPEv2 기본 설정

2. 최종 목표

11월 30일까지 업로드부터 판정·조치까지 전 과정이 시연에서 동작하는 것이 최종 목표이고, 세부 목표는 여섯 가지입니다.

목표	11/30까지의 기준	확인 방법
형식 범위 확대	PE·MS Office·HWP·HWPX와 그 안의 파일을 분석	직접 만든 시험 문서에서 내장 파일·링크·매크로를 모두 꺼냄
알려진 악성 즉시 차단	1차 확정 검사 근거로만 차단, 정상 파일 오차단 0건	정상 평가 묶음에서 1차 차단 건수
비용 안에서 놓침 최소화	형식별 정상 전송률 2~5% 안에서 놓친 악성 수를 줄임	형식별 평가표 (PE는 미니 프로젝트의 정상 전송률 2% 기준 결과, 놓친 악성 29개 → 18개와 비교)
동적 분석으로 확인	의심 파일을 CAPEv2에 자동 제출하고 결과를 회수	무해한 시험 문서가 게스트에서 실행되고 행동 규칙에 걸림
검사 못 한 것을 정상으로 두지 않음	암호 문서·오류·한도 초과·신뢰할 수 없는 동적 결과를 사유 코드와 함께 보류	보류 사유별 건수
근거 기록과 자동 조치	파일마다 규칙·징후·점수·행동 근거를 남기고, 저장소 태그와 폴더 이동을 자동으로 수행	관리자 화면과 S3 태그 확인

※ 미니 프로젝트: 본 과제의 선행 단계(11/1~11/9)로 Windows 실행 파일(PE)의 정적 분석(1차 확정 검사, LightGBM 모델, 결합층)을 구현하고 검증한 프로젝트입니다. 이하 본문에서도 같은 뜻으로 씁니다.

3. 서비스 범위 및 전략

본 프로젝트의 주요 고객층은 비용에 민감한 인프라 운영자입니다.

스피디는 **B2B MSP(관리형 서비스 제공자) 기업**으로, **Cloud·CDN·Security·AI**를 통합 제공합니다. 공개된 8건의 고객 사례를 보면, 스피디의 고객층은 크게 두 축으로 나뉩니다.

고객군	대표 사례	주 사용 솔루션	핵심 니즈
공공·교육기관	K사(일자리 정부기관), 대한결핵협회, 가천대학교	**CDN** + 인코딩·트랜스코딩·모니터링	**예산 제약** 속 안정적 콘텐츠 전송
게임·에듀테크 등 민간 기업	글로벌 게임사 S사, 교육기관 H사(에듀테크), 부동산 K사, 육아크루, 게임사 S사	**NHN Cloud(MSP)** + CDN + 보안, 알림 서비스	**인프라 비용 절감**과 글로벌 확장

공통점: 이들은 모두 **"콘텐츠를 대량으로 배포하는 조직"**이면서 동시에 **"IT 예산이 한정된 조직"**입니다. 스피디의 고객 사례에서도 **"예산 편성에 대한 고민"**(K사), **"비용 부담"**(부동산 K사), **"알림톡 비용 50% 이상 절감"**(육아크루), **"단가 약 30% 이상 절감"**(게임사 S사)처럼 비용 이야기가 반복적으로 등장합니다.

즉, 이러한 **스피디의 고객은 "보안은 필요하지만, 비용을 최소화해야 하는" 조직**입니다.

공공·교육기관: "예산은 부족한데 파일은 많다"

스피디의 K사 CDN 고객 사례를 보면, 월평균 약 4만 명이 쓰는 사이버 교육 플랫폼에 **다수의 콘텐츠 개발사가 제공한 패키징 콘텐츠**를 CDN으로 전송합니다. 기존 CDN은 단순 전송과 모니터링만 제공해, 영상 인코딩과 오류 원인 파악에는 별도 솔루션을 구축하거나 서비스를 이용해야 하는 **예산 편성의 고민**이 있었습니다.

동적 분석 비용 부담

공공기관은 추가 보안 예산이 별도로 책정되기 어렵고, 동적 분석 샌드박스로 보내는 파일의 비율을 계산하지 않는다면 **IT 예산 규모를 초과할 가능성이 있습니다.**

이러한 고객들은 **"모든 악성코드를 100% 잡는 것"**보다 **"의심스러운 2~5%만 정밀 검사"**하는 것을 원한다고 판단합니다.

본 프로젝트는 이러한 비용 문제를 해소하기 위해 **고객이 원하는 정밀 검사 수준에 맞춰 필요한 비율만큼 동적 분석하는 계층적 파이프라인을 제공**합니다.

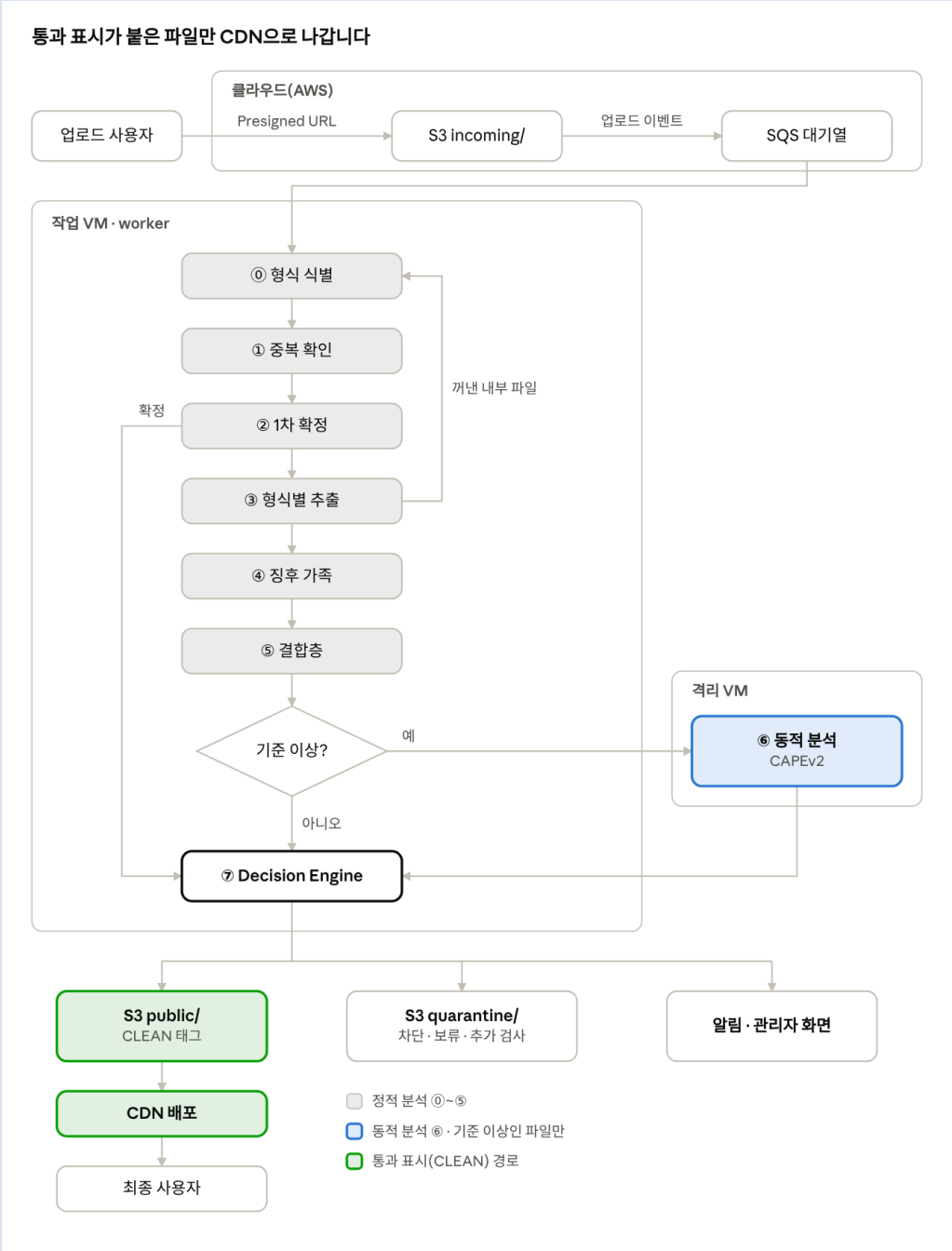
- 범위 밖: 개인용 백신, PC에 설치하는 엔드포인트 보안, 메일 첨부 검사

출처: 스피디 고객 사례 8건(speedykorea.com/resource/case-study), 2026-11-11 확인

4. 전체 아키텍처

파일은 업로드 → 정적 분석(⓪~⑤) → 동적 분석(⑥) → 최종 판정(⑦) → 조치의 한 방향으로 흐르고, 형식마다 다른 것은 ③ 추출 단계뿐입니다.

4.1 서비스 흐름도

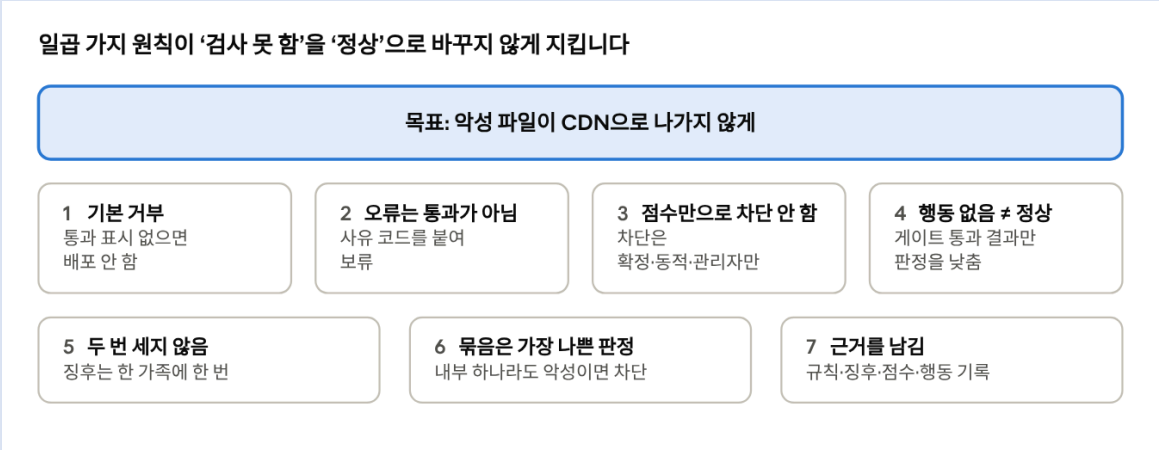


[그림 4-1] 서비스 흐름 · 업로드부터 배포까지

- 업로드는 짧게 만료되는 업로드 주소(Presigned URL)로 저장소의 incoming/에만 들어갑니다. 이 폴더는 외부에서 내려받을 수 없습니다.

- 저장소 이벤트가 대기열(SQS)에 들어가면, 작업 VM의 gateway 컨테이너가 파일을 하나씩 받아 오고 worker 컨테이너가 ⓪~⑤를 수행합니다(10.1 Docker 구성).
- 단계 번호: ⓪ 형식 식별, ① 중복 확인, ② 1차 확정 검사, ③ 형식별 추출, ④ 징후 가족, ⑤ 결합층, ⑥ 동적 분석, ⑦ Decision Engine.
- 통과한 파일만 public/으로 옮겨지고 CDN은 public/만 배포합니다. 나머지는 quarantine/에 남습니다.

4.2 핵심 원칙



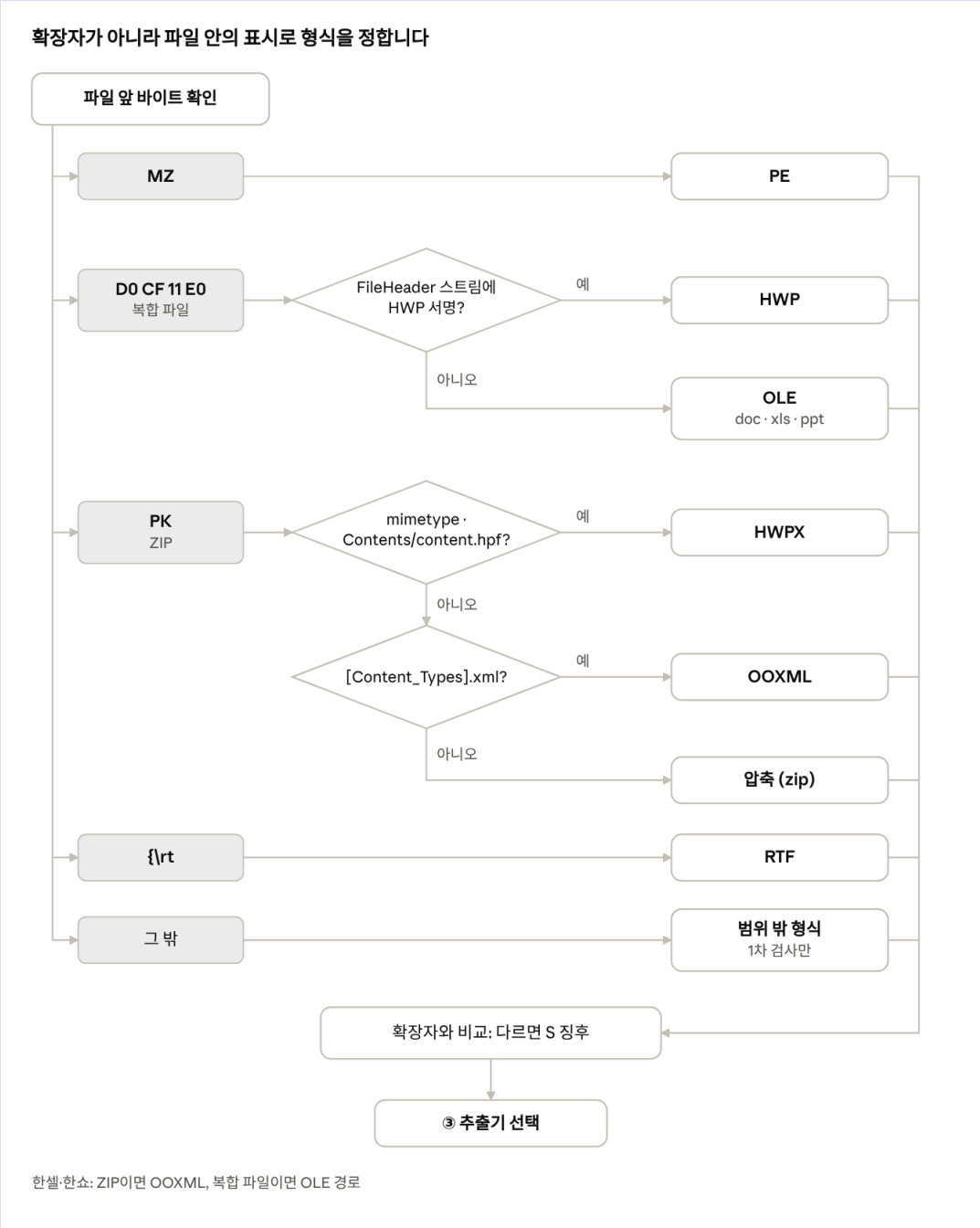
[그림 4-2] 핵심 원칙 7가지

1. **기본 거부:** 통과 표시(CLEAN 태그)가 없는 파일은 배포하지 않습니다.
2. **오류는 통과가 아닙니다:** 오류·시간 초과·한도 초과는 사유 코드를 붙여 보류합니다.
3. **점수만으로 차단하지 않습니다:** 차단은 1차 확정, 동적 분석의 악성 행동 확인, 관리자 판정에서만 나옵니다.
4. **행동 없음은 정상이 아닙니다:** 신뢰도 게이트를 통과한 동적 결과만 판정을 낮출 수 있습니다.
5. **같은 사실을 두 번 세지 않습니다:** 징후는 한 가족에만 넣고, 가족 안에서는 한 번만 셉니다.
6. **묶음은 가장 나쁜 판정을 따릅니다:** 압축·문서 안의 파일 중 하나라도 악성이면 전체를 막습니다.
7. **근거를 남깁니다:** 파일마다 어떤 규칙·징후·점수·행동으로 판정했는지 기록합니다.

5. 정적 분석 상세

정적 분석은 ⓪~⑤ 단계이고, 원본 파일과 꺼낸 모든 내부 파일이 같은 단계를 거칩니다. ① 중복 확인은 같은 SHA-256을 이미 판정했으면 그 결과를 다시 쓰는 단계라 따로 다루지 않습니다.

5.1 ⓪ 형식 식별 (매직 바이트, 확장자 위조)

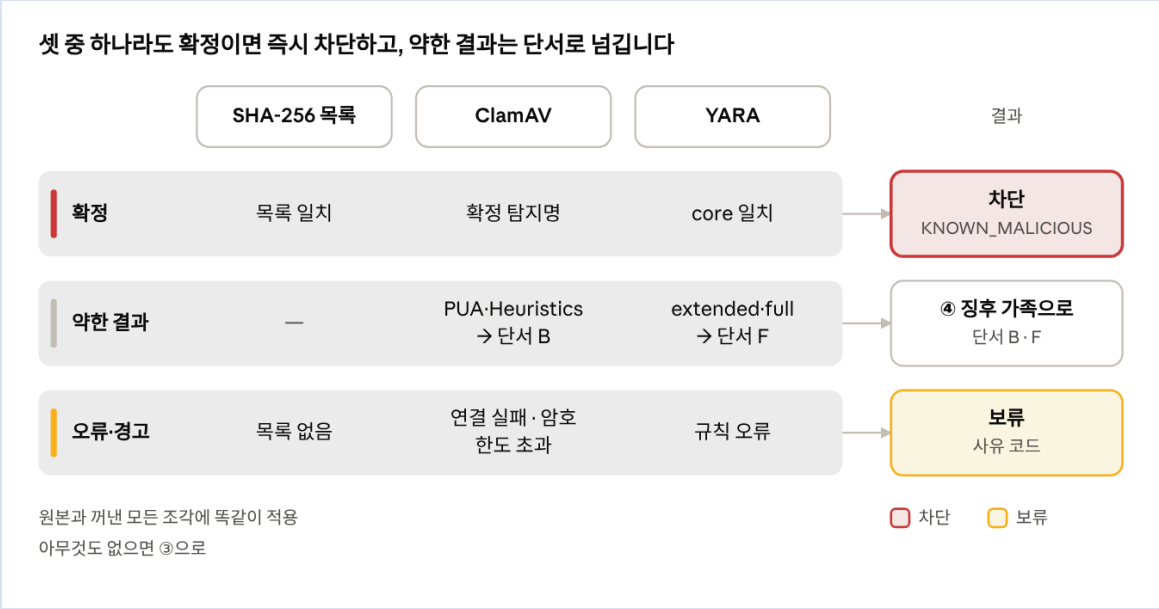


[그림 5-1] ⓪ 형식 식별 · 머리 바이트로 갈래 나누기

- 확장자가 아니라 파일 앞부분의 매직 바이트와 내부 구조로 형식을 정합니다. 공개 분석 플랫폼 Assemblyline도 파일명과 확장자를 보지 않습니다(Assemblyline).

- 기본 도구는 libmagic(python-magic)입니다. 한글 문서는 Google Magika 모델에 라벨이 없어, 자체 규칙(복합 파일 안의 FileHeader 스트림, ZIP 안의 mimetype과 Contents/content.hpf)으로 식별합니다(Magika 모델 카드).
- 실제 형식과 확장자가 다르면(예: 보고서.docx인데 실제로는 실행 파일) 구조 이상(S) 징후로 기록합니다.
- 식별 결과로 ③의 추출기를 고릅니다. 범위 밖 형식은 ②까지만 검사하고 정책에 따라 처리합니다.

5.2 ② 1차 확정 검사 (SHA-256 / ClamAV / YARA)



[그림 5-2] ② 1차 확정 검사 · 세 검사와 세 갈래

검사	확정 (즉시 차단)	단서 (④으로)	보류
SHA-256 목록	알려진 악성 목록과 일치	—	목록 파일 없음
ClamAV	확정 탐지명	PUA·Heuristics 탐지 → 단서 B	연결 실패·시간 초과, 암호·한도 초과 경고
YARA	core 묶음 일치	extended·full 일치 → 단서 F	규칙 오류

- ClamAV의 암호·한도 초과·매크로 경고는 기본값이 꺼짐이라 켭니다. 결과는 차단이 아니라 보류 사유나 징후로 씁니다(ClamAV 설정 예시).
- 미니 프로젝트에서 YARA core가 정상 파일 1건을 차단했으므로, 확정에 쓰는 규칙은 정상 묶음으로 오탐을 잰 뒤 쓰고 오탐을 낸 규칙은 단서로 내립니다.

5.3 ③ 형식별 추출 (PE·OLE·OOXML·HWP·HWPX·압축)



[그림 5-3] ③ 형식별 추출기 6개

형식	여는 방법	꺼내는 것	도구
PE	PE 구조 해석	특성 2,568개, ImpHash, TLSH	thrember, pefile (미니 프로젝트와 동일)
OLE (doc·xls·ppt)·RTF	복합 파일 스트림 열기, 기본 암호 복호화 시도	VBA·XLM 매크로, DDE, 내장 개체, CLSID	olefile, oletools, msoffcrypto-tool
OOXML (docx·xlsx·pptx 계열)	ZIP 멤버 열기	vbaProject.bin, 외부 관계, 내장 개체	zipfile, oletools
HWP 5.x	복합 파일을 열고 스트림을 raw deflate로 풀기, 배포용 문서는 명세대로 복호화	FileHeader 플래그, BinData의 OLE 개체·EPS, 스크립트, 하이퍼링크	olefile, zlib, 자체 레코드 파서
HWPX	ZIP과 XML	BinData/, Scripts/, 암호화 정보, 본문 링크	zipfile, XML 파서
압축 (zip)	한도를 건 추출	내부 파일, 암호화 여부, 압축률	zipfile

한셀(.cell)·한쇼(.show)는 공식 규격을 찾지 못해, 머리 바이트가 ZIP이면 OOXML 추출기, 복합 파일이면 OLE 추출기로 보냅니다.

5.4 ④ 징후 가족 (A·B·F + M·X·E·O·S)

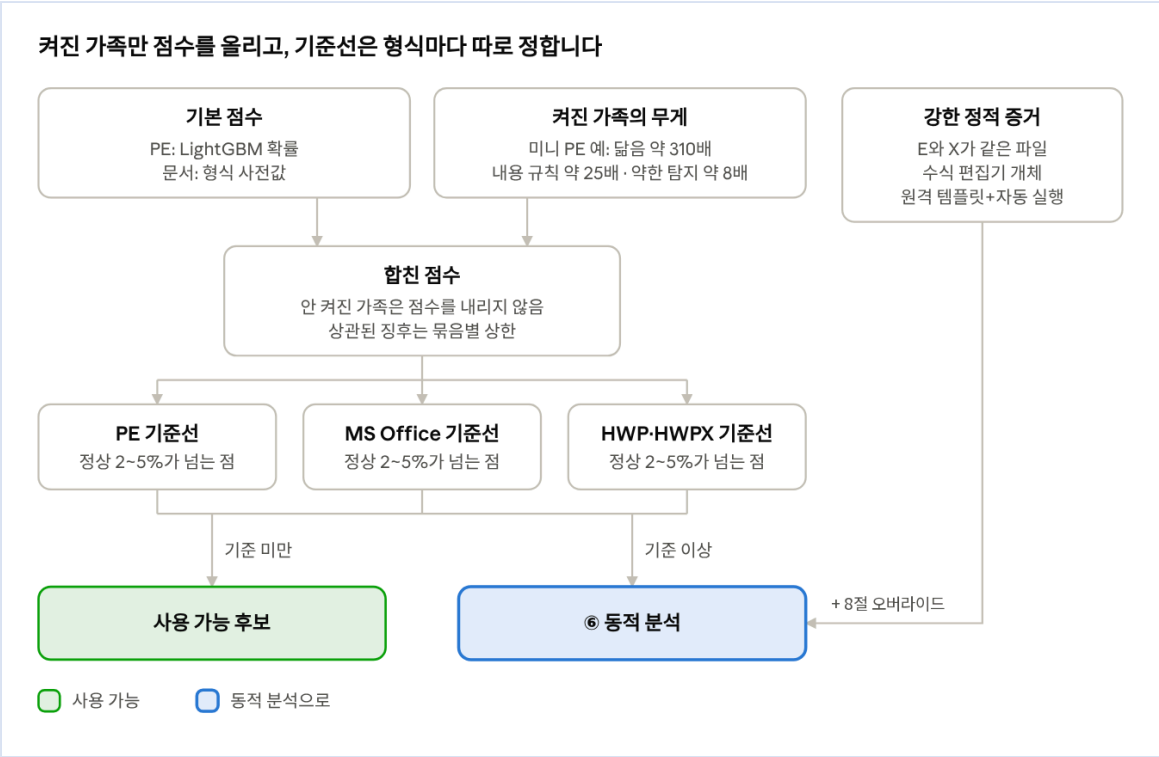


[그림 5-4] ④ 징후 가족 8개 × 형식 3개

가족	뜻	예
A 닮음	알려진 악성과 구조가 비슷함	TLSH 거리, ImpHash 일치
B 약한 탐지	백신이 '의심' 수준으로만 탐지	ClamAV PUA·Heuristics
F 내용 규칙	확장 규칙집과 일치	YARA extended·full
M 자동 실행	문서를 열면 스스로 실행되는 코드	자동 실행 매크로 + 쓰기·실행 키워드, XLM Auto_Open, DDE, HWP 스크립트
X 외부 참조	파일 밖을 가리키는 연결	원격 템플릿, 임시 폴더나 실행 파일을 가리키는 링크
E 내장 실행물	안에 든 실행 파일·스크립트·바로 가기	Office 내장 개체, HWP BinData의 OLE 개체
O 숨김·난독화	감추려는 흔적	VBA 코드 바꿔치기, 숨긴 시트, 긴 인코딩 블록
S 구조 이상	규격과 다른 구조	확장자 불일치, 수식 편집기 개체, EPS, 레코드 크기 이상

매크로가 있다는 사실만으로는 징후로 치지 않습니다. 업무용 엑셀에는 매크로가 흔하기 때문입니다(Assemblyline Oletools 점수표).

5.5 ⑤ 결합층 (로그 우도비, 형식별 기준선)



[그림 5-5] ⑤ 결합층 · 점수 계산과 형식별 기준선

- **합친 점수 = 형식별 기본 점수 + 켜진 징후 가족의 무게 합.** PE의 기본 점수는 LightGBM 확률이고, 문서는 형식의 사전값에서 시작합니다.
- **무게는 데이터로 정합니다.** 미니 프로젝트에서는 닮음이 약 310배, 내용 규칙이 약 25배, 약한 탐지가 약 8배였습니다. 문서처럼 라벨 데이터가 적은 형식은 약한 징후는 낮게, 강한 징후는 하나만으로 기준선을 넘게 주는 계단 점수로 시작합니다.
- **기준선은 형식별로 따로 둡니다.** 형식마다 정상 파일의 2~5%만 동적 분석으로 가도록 정합니다. 공개 대규모 비교에서도 형식별 모델이 공유 모델보다 나았습니다(EMBER2024).
- **상관된 징후는 한 번만 셉니다.** 로그 우도비 합은 징후끼리 상관되면 점수가 과장되므로, 가족 안에서는 하나만 세고 묶음마다 상한을 둡니다.
- **강한 정적 증거는 따로 표시합니다.** 예: 한글 문서의 내장 실행 파일을 같은 문서의 링크가 가리킴(E와 X가 같은 파일을 가리킴), 수식 편집기 개체, 원격 템플릿과 자동 실행이 함께 있음. 이 표시는 8절의 조건부 오버라이드에 쓰입니다.

6. 재귀 분석과 한도

압축 파일과 문서 안의 파일은 꺼내서 ⓪부터 다시 검사하고, 묶음 전체의 판정은 내부에서 가장 나쁜 판정(차단 > 보류 > 추가 검사 중 > 사용 가능)을 따릅니다. 같은 해시의 조각은 한 번만 검사하며, 끝없이 풀지 않도록 네 가지 한도를 둡니다.

재귀 깊이	내부 파일 수	푼 용량 합계	추출 시간
5단계 (LIMIT_DEPTH)	300개 (LIMIT_COUNT)	300MB (LIMIT_SIZE)	60초 (TIMEOUT)

한도에 걸리거나 검사하지 못한 파일은 정상으로 두지 않고 사유 코드와 함께 보류합니다. 이미 꺼낸 파일의 검사는 계속하며, 그중 하나라도 악성이면 차단이 우선합니다.

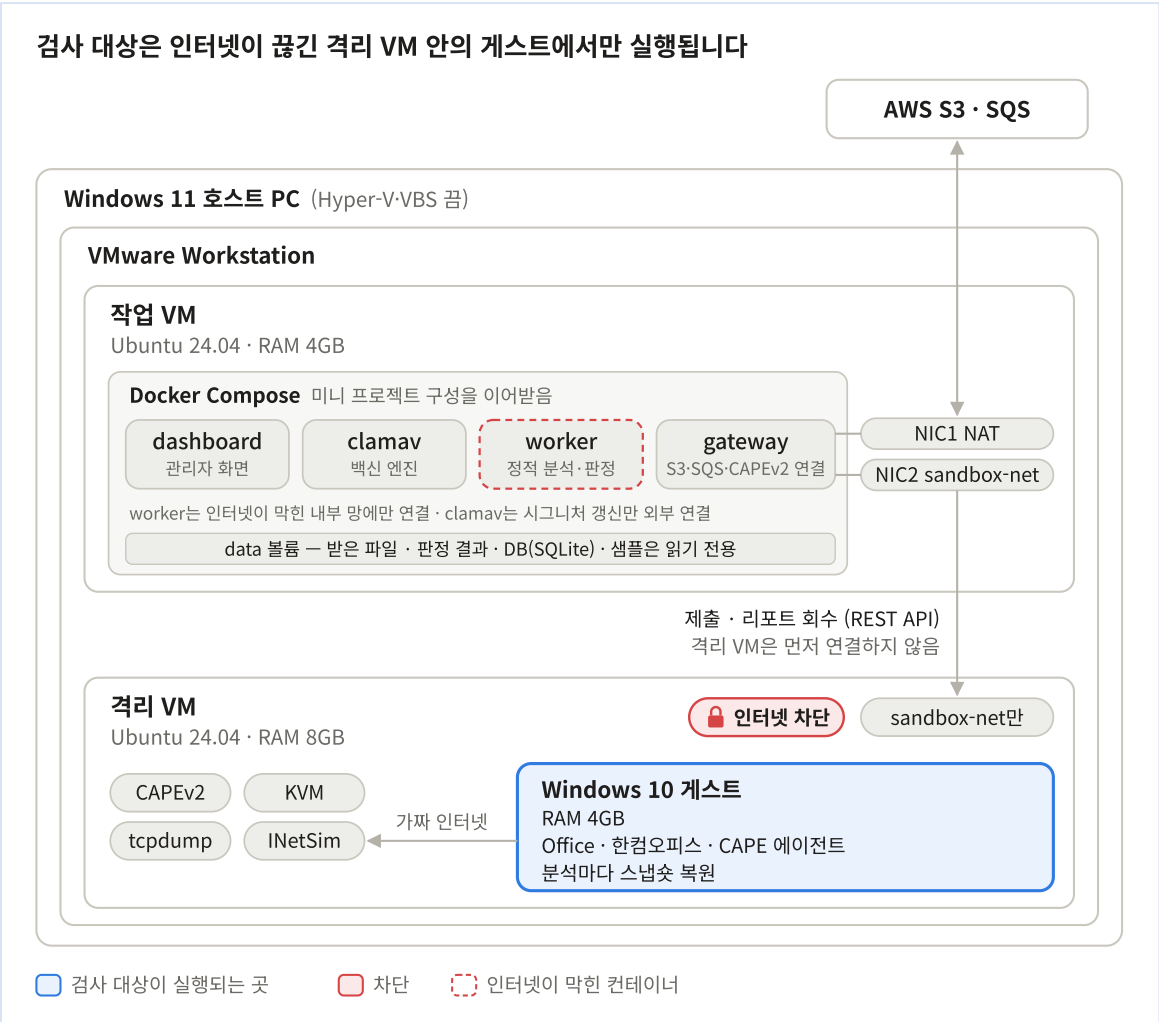
판정값	사유 코드
UNSCANNABLE 다시 해도 결과가 같음	ENCRYPTED(암호) · LIMIT_DEPTH · LIMIT_COUNT · LIMIT_SIZE(한도 초과) · UNSUPPORTED(분석기 없음)
HOLD_REVIEW 재검사·사람 판단 필요	TIMEOUT · PARSE_ERROR · ENGINE_ERROR · DYN_FAILED(동적 실행 실패) · DYN_LOW_TRUST(동적 신뢰 낮음) · STRONG_STATIC(강한 정적 증거)

한도 값은 Assemblyline·Cloudflare·ClamAV의 기본값을 참고한 예시이며, 시험 묶음과 정상 설치 파일로 다시 재어 조정합니다.

7. 동적 분석 상세 (CAPEv2)

동적 분석은 정적 분석이 기준 이상으로 본 파일만 CAPEv2의 Windows 10 게스트에서 열거나 실행합니다. MS Office는 CAPEv2의 기존 패키지를 쓰고, 한글 문서는 패키지와 행동 규칙을 직접 만듭니다. CAPEv2 관련 내용은 소스와 문서를 읽은 결과이고, 우리 환경에서의 확인은 구현 단계에서 합니다.

7.1 환경 구성 (VMware + Windows 10 게스트)



[그림 7-1] 동적 분석 환경 · 호스트 > VM(Docker) > 게스트

구성	사양 (계획)	역할
호스트 PC	Windows 11 Pro, VMware Workstation	Hyper-V와 가상화 기반 보안을 꺼야 VM 안에서 KVM이 동작 (Broadcom)
작업 VM	Ubuntu 24.04, RAM 4GB, 디스크 60GB, Docker Compose	컨테이너 gateway·worker·ClamAV·관리자 화면과 DB. gateway가 CAPEv2에 제출하고 리포트를 회수(10.1 Docker 구성)
격리 VM	Ubuntu 24.04, RAM 8GB, 디스크 120GB	CAPEv2, KVM, 가짜 인터넷(INetSim), 패킷 기록. 실제 인터넷 차단

구성	사양 (계획)	역할
Windows 10 게스트	RAM 4GB, 디스크 60GB	MS Office·한컴오피스·CAPE 에이전트. 분석마다 깨끗한 스냅숏으로 복원

- 격리 VM의 `/proc/cpuinfo`에 vmx가 보여야 게스트가 뜹니다. 중첩 환경의 처리 시간 자료는 찾지 못해 직접 잽니다.
- 게스트의 Windows 10과 Office 2016·2019는 2025년 10월에 지원이 끝났습니다(Microsoft). 인터넷이 끊긴 분석 전용 게스트라 쓸 수는 있지만, 라이선스는 필요합니다.

7.2 형식별 제출 방법과 한계



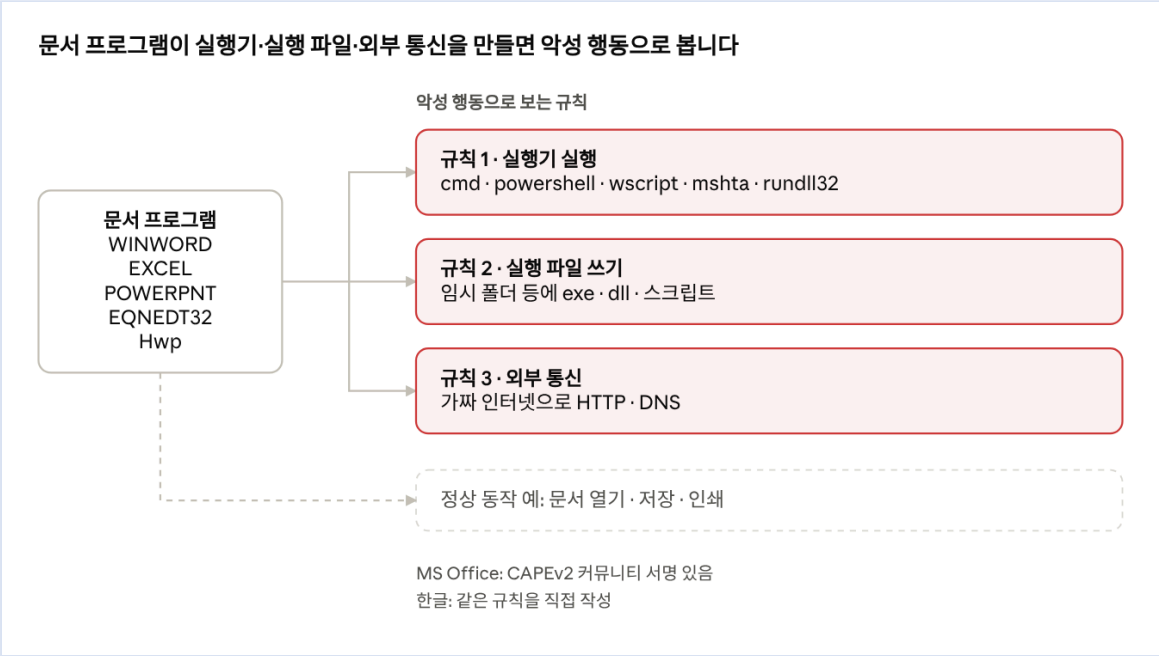
[그림 7-2] 형식별 제출 경로 7가지

대상	제출 방법	한계
PE (exe·dll)	exe·dll 패키지	없음
MS Office 문서	doc·xls·ppt 패키지. 문서를 Office의 '신뢰할 수 있는 위치'에 두고 열어 매크로가 돌게 함	게스트의 Office 설치 경로가 다르면 매크로가 실행되지 않을 수 있음 → 무해한 매크로 문서로 확인
원격 템플릿 문서	같은 패키지 + 가짜 인터넷 연결	실제 주소로 나가지 않으므로 2단계 내용은 보지 못함
한글 문서의 내장 파일	정적 단계가 꺼낸 파일들을 zip으로 묶어, 실행할 파일을 지정해 제출. 서명된 exe와 악성 dll이 같은 폴더에 풀려 DLL 바꿔치기도 재현	문서의 링크 클릭 과정은 생략됨

대상	제출 방법	한계
한글 문서 자체	직접 만든 hwp 패키지	CAPEv2의 hwp 패키지는 옛 코드라 시작 단계에서 실패하는 것으로 보임. 링크 클릭과 경고창 수락을 자동으로 하지 못함
한셀·한쇼	기본 연결 프로그램으로 열기	전용 패키지 없음
압축 파일	정적 단계가 풀어 내부 파일만 제출	CAPEv2의 압축 패키지는 docx·hwp를 실행 대상으로 고르지 않음

제출할 때는 패키지를 항상 지정합니다. 자동 선택에 맡기면 HWPX가 압축 파일로 처리됩니다(CAPEv2 패키지 문서).

7.3 행동 판정 규칙 (3가지)

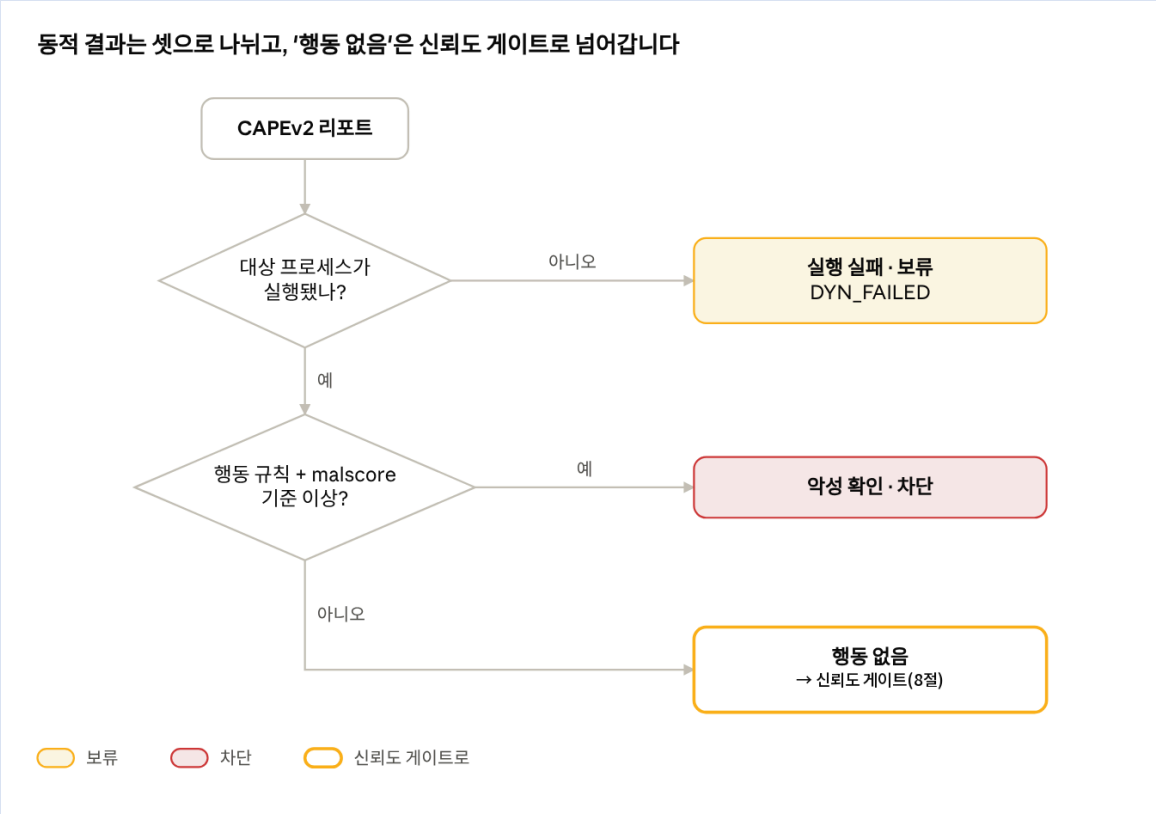


[그림 7-3] 행동 판정 규칙 3가지

1. **문서 프로그램이 실행기를 띄움:** Word·Excel·PowerPoint·수식 편집기·한글이 cmd·powershell·wscript·mshta·rundll32를 자식 프로세스로 만듦
2. **문서 프로그램이 실행 파일을 씀:** 임시 폴더 등에 exe·dll·스크립트를 만듦
3. **문서 프로그램이 외부와 통신함:** 가짜 인터넷으로 HTTP·DNS 요청을 보냄

MS Office는 CAPEv2 커뮤니티 서명이 이 세 가지를 이미 봅니다(martians_office.py). 한글(Hwp.exe)을 보는 서명은 찾지 못해 같은 규칙을 직접 만듭니다.

7.4 동적 결과 해석 (악성 확인 / 행동 없음 / 실행 실패)



[그림 7-4] 동적 결과 세 갈래

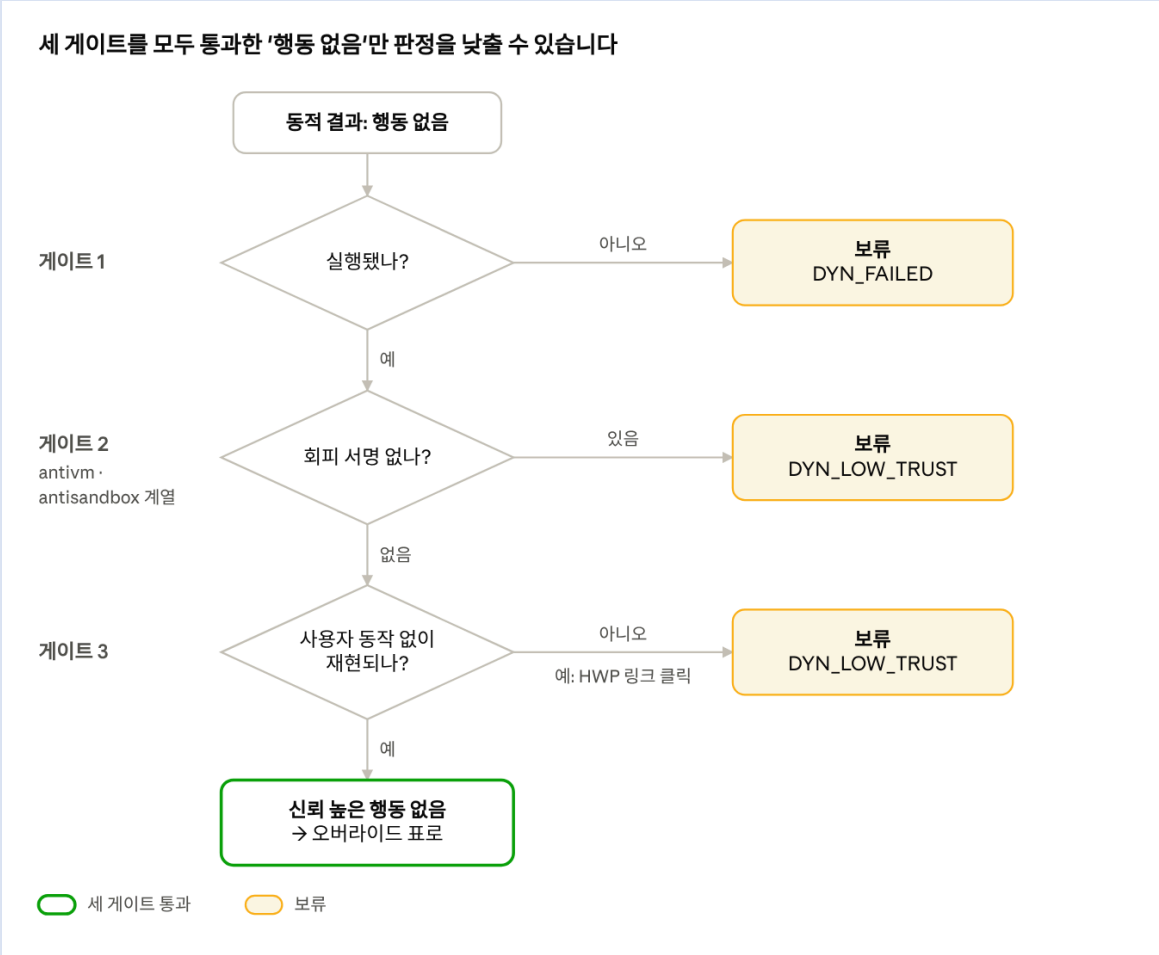
결과	조건	뜻	다음
악성 확인	행동 규칙에 걸리고 malscore가 기준 이상	실제로 악성 행동을 함	차단 (8절)
행동 없음	실행은 됐지만 규칙에 걸린 행동이 없음	정상일 수도, 클릭·주소·환경 조건이 안 맞았을 수도 있음	신뢰도 게이트로 판단 (8절)
실행 실패	패키지 오류, 프로세스 없음, 시간 초과	판단 불가	보류 (DYN_FAILED)

malscore는 CAPEv2가 서명의 심각도·신뢰도·가중치로 계산하는 0~10점 점수입니다(CAPEv2 서명 문서).

8. Decision Engine — 최종 판정

Decision Engine은 정적 결과와 동적 결과를 받아 판정값 5가지 중 하나를 고르고 조치를 실행합니다. 동적 결과는 믿을 수 있을 때만 판정을 낮출 수 있고, 확실한 악성 행동은 정적 점수와 관계없이 판정을 올립니다.

8.1 신뢰도 게이트 (회피 시그니처, 실행 실패)



[그림 8-1] 신뢰도 게이트 3단계

게이트	확인하는 것	걸리면
1. 실행 여부	대상 프로세스가 실제로 떴는가, 패키지 오류·시간 초과는 없는가	실행 실패 → 보류 (DYN_FAILED)
2. 회피 시그니처	가상 환경·샌드박스 탐지 서명(이름이 antivm·antisandbox로 시작하는 커뮤니티 서명 등)이 켜졌는가	신뢰 낮음 → 보류 (DYN_LOW_TRUST)
3. 사용자 동작 필요	한글 문서의 링크 클릭처럼 자동으로 재현하지 못하는 단계가 있는가	신뢰 낮음 → 보류 (DYN_LOW_TRUST)

세 게이트를 모두 통과한 '행동 없음'만 신뢰 높음으로 보고 판정을 낮추는 데 씁니다. CAPEv2 커뮤니티에는 antivm 계열 서명이 약 34개, antisandbox 계열이 약 23개 있습니다(CAPESandbox community).

8.2 조건부 오버라이드 (malscore ≥ 7 등)

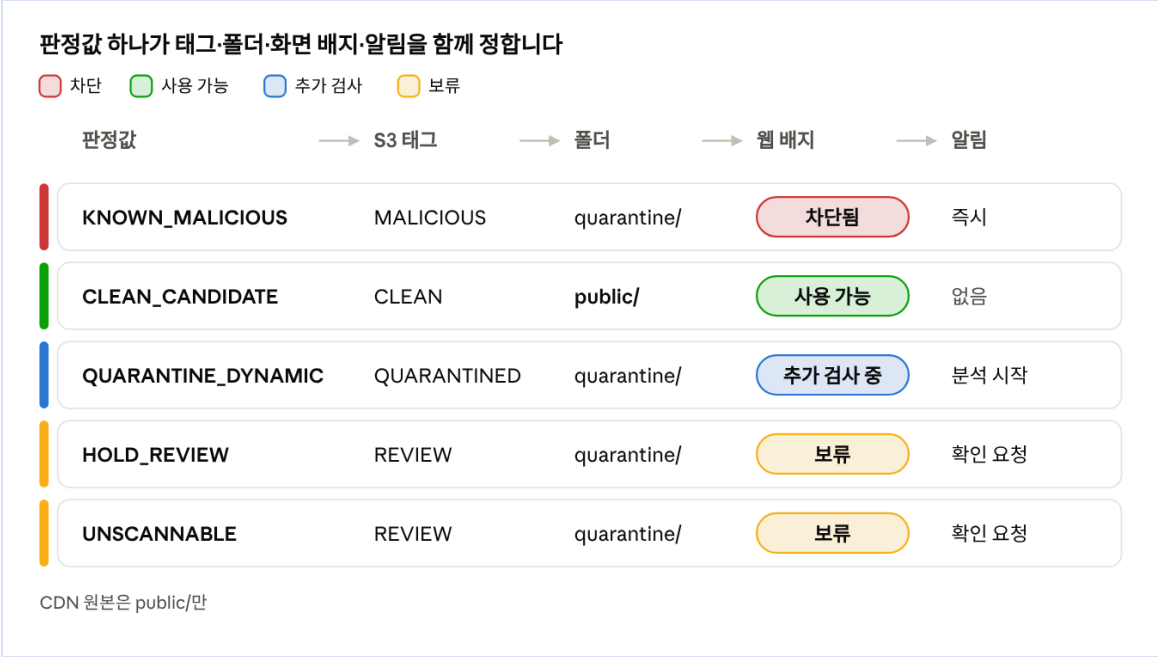


[그림 8-2] 정적 결과 × 동적 결과 판정표

- **올림 — 동적 악성 확인:** malscore가 7 이상이고 7절의 행동 규칙이 하나 이상 걸리면 정적 점수와 관계없이 차단합니다.
- **올림 — 1차 확정:** 해시·백신 확정·YARA core 근거는 동적 결과와 관계없이 차단합니다.
- **유지 — 강한 정적 증거:** 5절 ⑤의 강한 증거가 있으면 동적 '행동 없음'으로 낮추지 않고 보류합니다 (STRONG_STATIC).
- **중간 — 판단 어려움:** malscore 4~7이거나, 행동 규칙 없이 서명만 높으면 보류하고 관리자가 봅니다.
- **낮춤 — 신뢰 높은 행동 없음:** 게이트를 통과한 '행동 없음'이고 정적 점수가 의심 구간이면 사용 가능입니다. 정적 점수가 악성 구간이면 보류합니다.

malscore는 0~10점이고, CAPEv2의 실행 파일 판정 규칙도 4 미만을 'Clean', 4~6을 'Suspicious'로 둡니다(CAPEv2 scoring.py). 기준 7과 4는 초깃값이고, 시험 문서와 정상 표본으로 조정합니다.

8.3 판정값 5종 매핑 (S3 태그, 웹 배지)



[그림 8-3] 판정값 5종의 조치

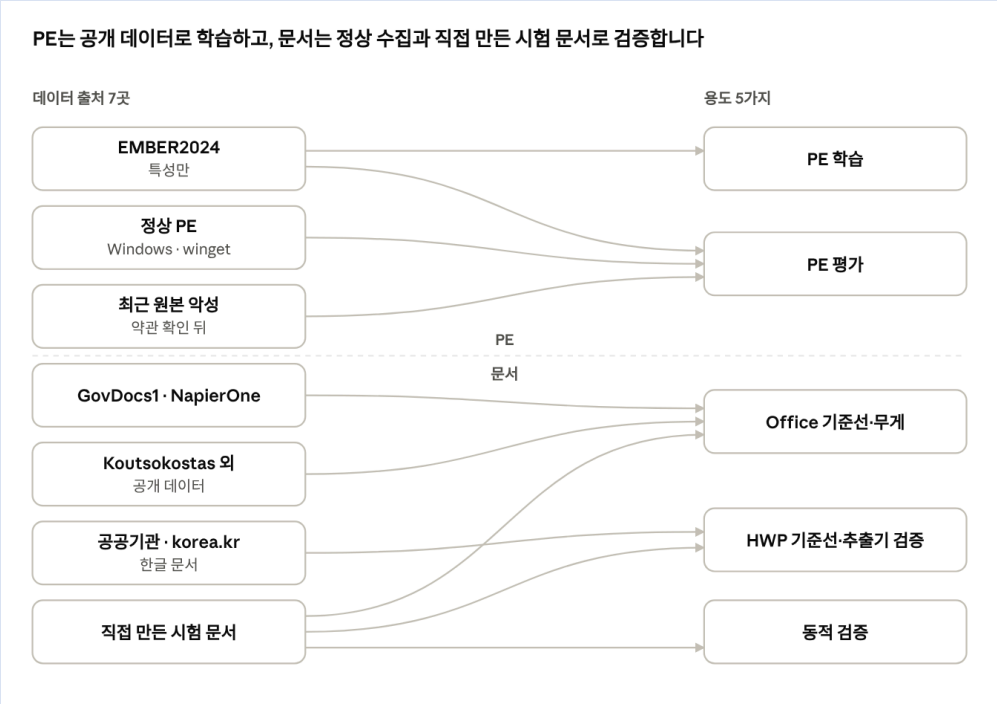
판정값	언제	S3 태그	폴더	웹 배지	알림
KNOWN_MALICIOUS	1차 확정, 동적 악성 확인, 관리자 차단	MALICIOUS	quarantine/	차단됨	즉시
CLEAN_CANDIDATE	기준 미만, 또는 신뢰 높은 행동 없음	CLEAN	public/	사용 가능	없음
QUARANTINE_DYNAMIC	기준 이상, 동적 분석 대기·진행	QUARANTINED	quarantine/	추가 검사 중	분석 시작
HOLD_REVIEW	오류, 동적 신뢰 낮음, 강한 정적 증거	REVIEW	quarantine/	보류	확인 요청
UNSCANNABLE	암호, 한도 초과, 분석기 없음	REVIEW	quarantine/	보류	확인 요청

판정값 이름은 미니 프로젝트 코드를 따르고, 차단 근거(1차·동적·관리자)는 별도 항목으로 남깁니다.

9. 데이터 및 평가

PE는 공개 데이터로 다시 학습하고, 문서는 정상 문서 수집과 직접 만든 시험 문서로 기준선과 동작을 확인합니다. 아래 데이터셋과 파이프라인은 아직 확정 전이며, 이렇게 하겠다는 예시 계획입니다.

9.1 데이터 수집 계획 (형식별)

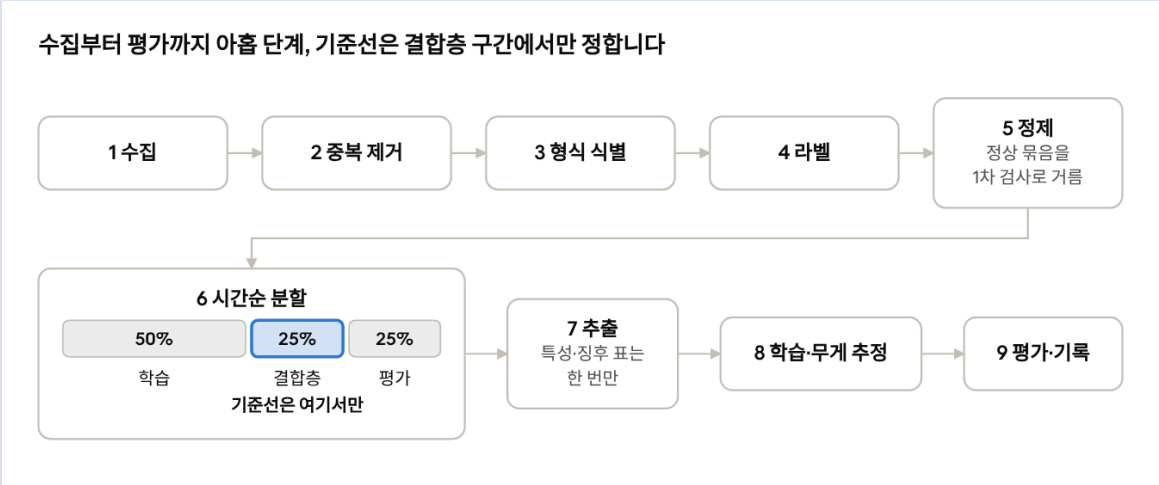


[그림 9-1] 데이터 출처 7곳 → 용도 5가지

형식·용도	정상	악성	규모 (예시)
PE 학습 (LightGBM 재학습)	EMBER2024 학습 구간 일부	같은 곳	각 10만 개, 주별로 고르게
PE 평가 (전 경로)	Windows 기본 파일, winget 설치 파일, 공개 빌드 묶음	최근 원본 악성(약관 확인 뒤), EMBER2024 시험·challenge 구간	각 1,000~2,000개
MS Office	GovDocs1(doc 76,605·xls 62,876·ppt 51,292개, 2010년 이전), NapierOne(DOCX·XLSX·PPTX 포함)	Koutsokostas 외 공개 데이터 (매크로 문서 악성 15,571 · 정상 2,968개) + 직접 만든 시험 문서	정상 5,000개, 악성 수천 개
HWP·HWPX	공공기관 게시판·korea.kr 공개 문서	공개 데이터 없음 → 직접 만든 시험 문서(내장 파일 + 링크 구조, 내용물은 무해)	정상 2,000개, 시험 50개
동적 검증	정상 문서 일부	직접 만든 시험 문서	형식별 10~20개

- EMBER2024는 2023년 9월~2024년 12월 파일의 특성과 라벨만 공개하고, 특성 추출기가 미니 프로젝트와 같아 바로 학습에 쓸 수 있습니다(EMBER2024).
- 시험 문서는 메모장을 여는 배치 파일처럼 무해한 내용물로 만들어, 악성 표본 없이 추출기와 동적 흐름을 확인합니다.
- 정부 문서가 HWPX로 바뀌는 중이라, .hwp가 아직 흔한 지금 수집을 시작합니다.

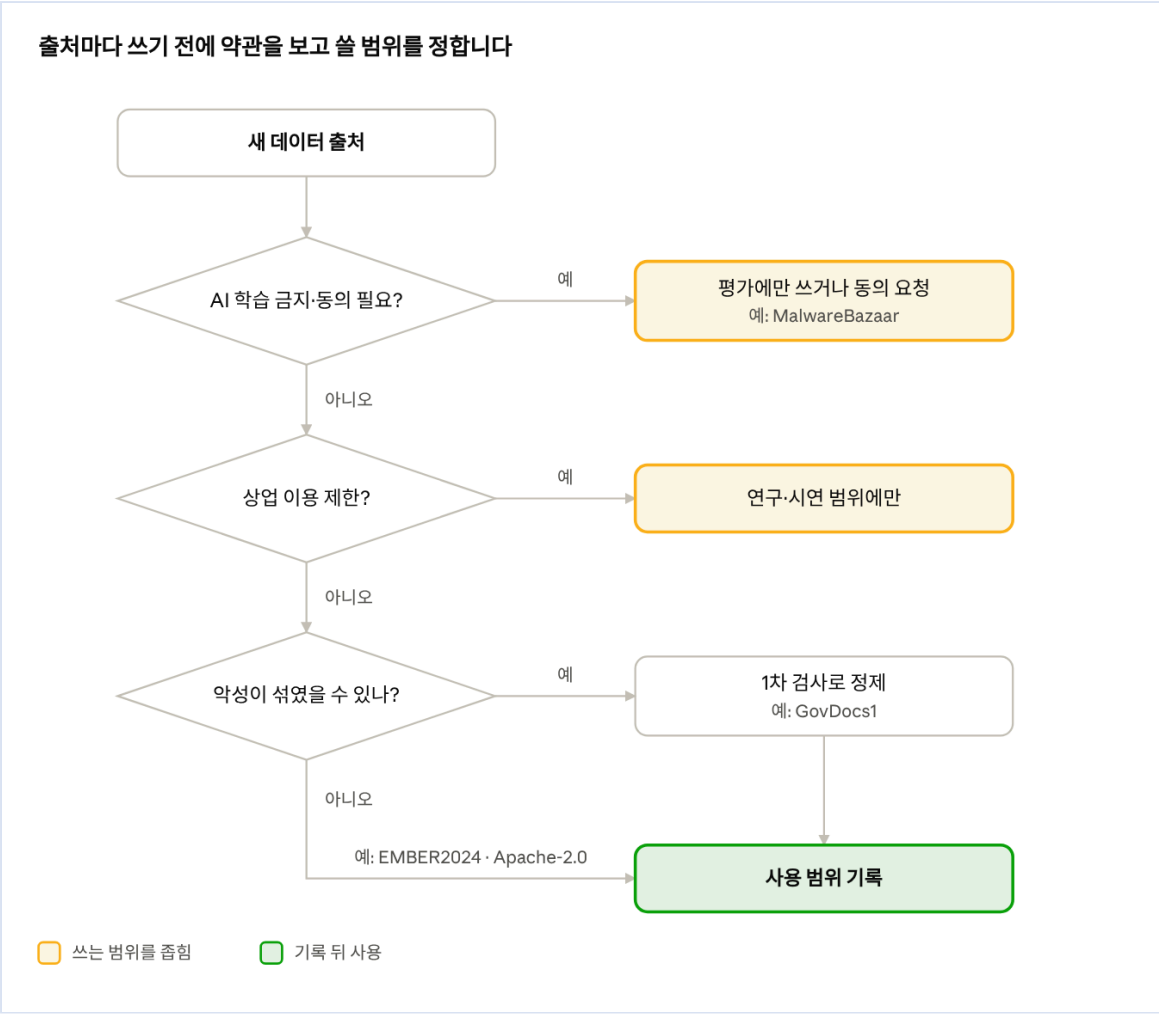
9.2 데이터 파이프라인 (예시)



[그림 9-2] 데이터 파이프라인 9단계 (예시)

1. **수집:** 출처·수집일·약관을 파일마다 기록합니다. 악성 표본은 격리된 VM에만 둡니다.
2. **중복 제거:** SHA-256으로 같은 파일을 없앱니다.
3. **형식 식별:** ⓪ 단계와 같은 식별기로 나눕니다.
4. **라벨:** 출처 기준(정상 묶음 / 악성 묶음 / 시험 문서)으로 붙입니다.
5. **정제:** 정상 묶음을 1차 확정 검사에 돌려 섞여 있는 악성을 빼고, 라벨이 충돌하는 파일은 제외합니다.
6. **시간순 분할:** 학습 50% / 결합층 25% / 평가 25%. 기준선은 결합층 구간에서만 정합니다.
7. **추출:** 특성·징후 표를 한 번만 만들어 저장합니다.
8. **학습·무게 추정:** PE는 LightGBM, 문서는 징후 가족 무게.
9. **평가·기록:** 형식별 지표를 실행 번호와 함께 남깁니다.

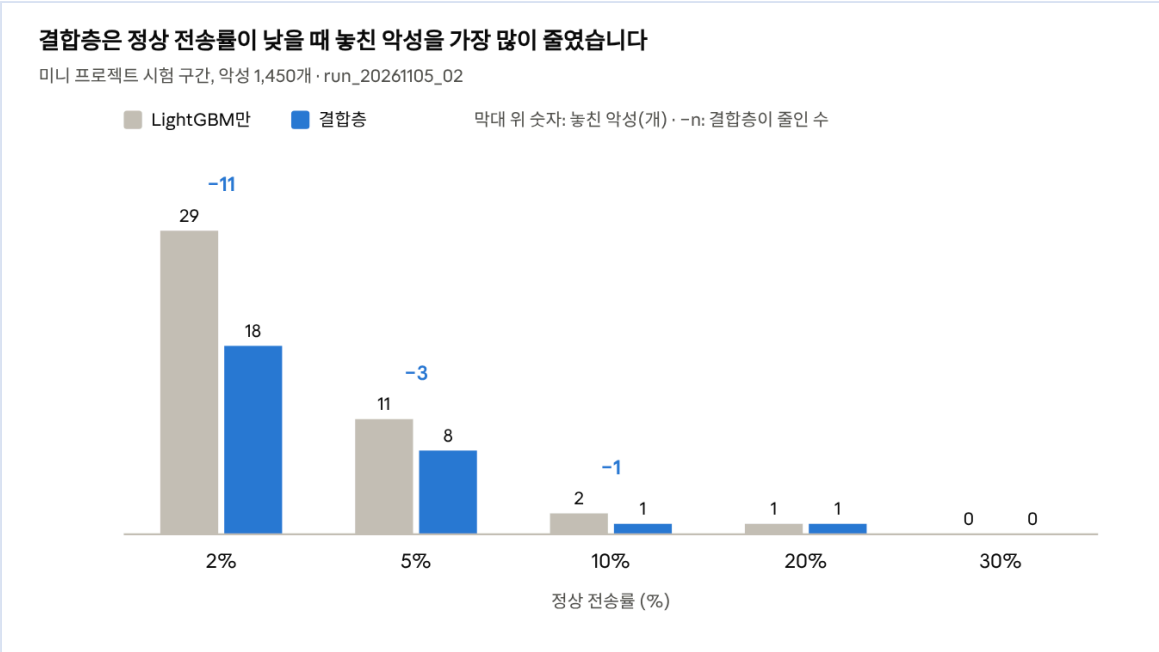
9.3 데이터 이용 약관 (MalwareBazaar, GovDocs1 등)



[그림 9-3] 데이터 사용 전 확인 4단계

출처	확인한 조건	우리 사용 범위
MalwareBazaar	비영리 목적, 대량 수집 금지, 사전 서면 동의 없이 AI 학습 금지(abuse.ch, 2026-10-21 개정)	평가용 표본만. 학습에 쓰려면 동의 요청
GovDocs1	악성코드가 섞여 있을 수 있다고 밝힘(Digital Corpora)	1차 검사로 거른 뒤 정상 기준선에만
NapierOne	44개 형식, HWP 없음. 문서 묶음은 암호 zip, 랜섬웨어 암호화 묶음도 있음(AWS Open Data)	Office 정상 표본 보완 (암호화 묶음은 제외)
Koutsokostas 외 (Zenodo)	연구용 공개 데이터, 원본과 정적 특징 포함. 상업 이용 조건은 확인 필요(Zenodo 4559436)	Office 무게 추정·평가
korea.kr	공공누리 유형을 건별로 확인(korea.kr)	정상 한글 문서
EMBER2024	Apache-2.0, 특성·라벨만 공개, 원본 파일 없음	PE 학습·평가
직접 만든 시험 문서	제한 없음	추출기·동적 검증

9.4 평가 지표 (형식별 전송률·미탐률)



[그림 9-4] 미니 프로젝트 · 정상 전송률별 놓친 악성

미니 프로젝트에서 쓴 기준을 형식별로 그대로 씁니다. 정상 전송률을 고정하고 그때 놓친 악성 수를 비교합니다.

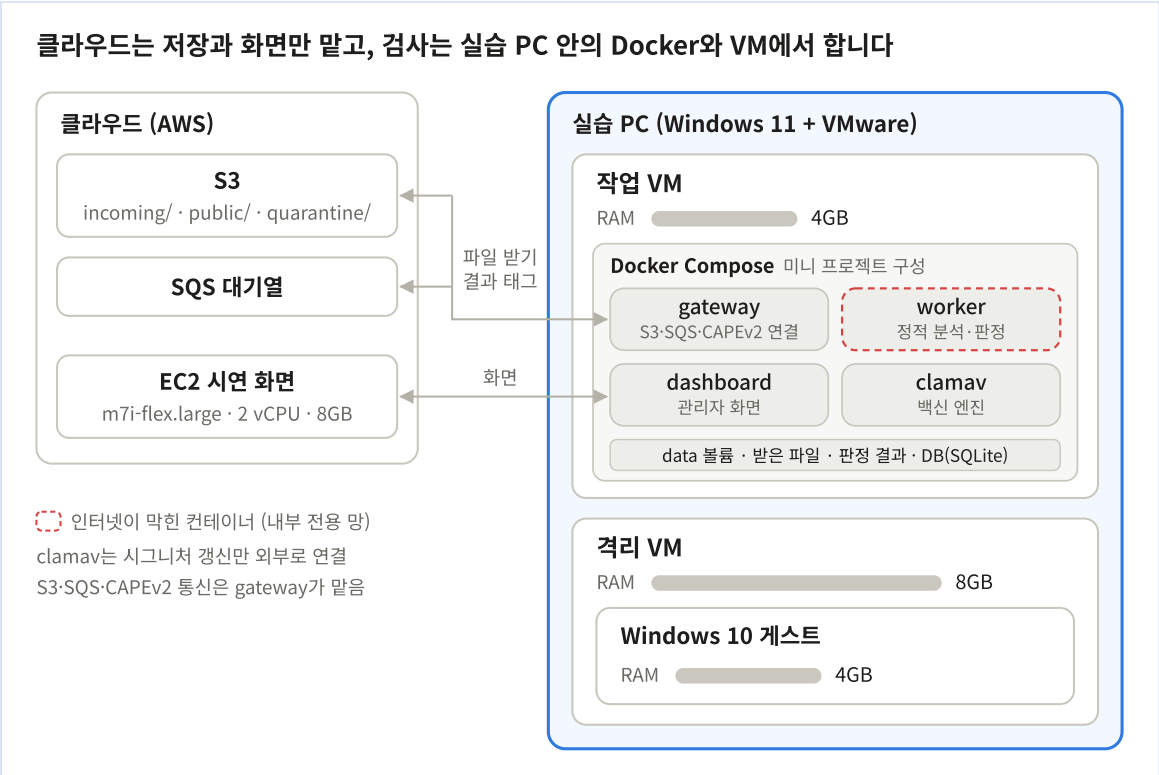
지표	뜻	목표
정상 전송률	정상 파일 중 동적 분석으로 간 비율	형식별 2~5%
미탐률	악성 중 사용 가능으로 통과한 비율	같은 전송률에서 낮을수록 좋음
1차 오차단	1차 확정으로 막힌 정상 파일	0건
보류율	사유 코드별 보류 비율	사유별로 집계
동적 신뢰율	동적 결과 중 신뢰도 게이트를 통과한 비율	형식별 측정
처리 시간	정적 파일당, 동적 건당 시간	정적 약 1초, 동적은 측정

평가는 수집 시간순으로 나눠 하고, 형식별 정상 표본 수를 함께 적습니다. 백신 몇 곳만 탐지하는 '까다로운 정상' 파일은 따로 묶어 봅니다.

10. 기술 인프라 및 비용

검사는 보유한 실습 PC 안의 VM에서 하고, 클라우드는 저장소·대기열·시연 화면만 씁니다. 그래서 추가 비용은 클라우드 사용량과 게스트 소프트웨어 라이선스가 대부분입니다.

10.1 환경 구성 (호스트·VM·게스트)



[그림 10-1] 자원 배치 · 클라우드와 실습 PC(Docker 포함)

구성	위치·사양	비용
저장소·대기열	AWS S3(incoming/·public/·quarantine/) + SQS	사용량만큼. 시연 규모에서는 미미함
시연 화면 서버	AWS EC2 m7i-flex.large (2 vCPU, 8GB)	서울 기준 시간당 $0.11771(AWS 가격표, 2026-11-07). 하루 8시간이면 약 $0.94
실습 PC	Windows 11 Pro + VMware Workstation. 작업 VM 4GB(Docker Compose), 격리 VM 8GB(게스트 4GB 포함)	보유 장비
게스트 소프트웨어	Windows 10, MS Office, 한컴오피스	라이선스 필요(보유 여부 확인)

작업 VM의 Docker 구성: 미니 프로젝트에서 작업 VM에 꾸린 Docker Compose 환경을 이어받습니다. 분석 컨테이너는 미니 프로젝트처럼 인터넷이 막힌 내부 망에만 연결하고, S3·SQS·CAPEv2와의 통신은 gateway 컨테이너가 따로 맡습니다.

컨테이너	하는 일	네트워크
gateway	SQS 수신, S3에서 파일 받기, 판정 뒤 태그 붙이기·폴더 이동, CAPEv2 제출·리포트 회수	외부망(NAT), sandbox-net
worker	⓪~⑤ 정적 분석과 ⑦ Decision Engine. 샘플은 읽기 전용으로 마운트	내부 전용 망(인터넷 차단)
clamav	ClamAV 엔진(clamd)	내부 전용 망 + 시그니처 갱신용 외부망
dashboard	관리자 화면(Streamlit)	작업 VM 안(127.0.0.1)에만 공개
analyzer	데이터 추출·학습·평가 일괄 실행(필요할 때만)	내부 전용 망
data 볼륨	받은 파일, 판정 결과, DB(SQLite)	컨테이너끼리 공유

처리 용량: 게스트 한 대는 건당 약 260초로 하루 최대 약 330건을 처리합니다(계산값). 하루 1만 개 업로드에 정상 2%를 보내면 약 200건이라 한 대로 되지만, 5%(약 500건)면 게스트가 두 대 필요합니다. 중첩 환경에서는 더 느릴 수 있어 실측으로 다시 잽니다.

이후 클라우드 이전: AWS는 2026년부터 M7i·M7i-flex 등 일반 인스턴스에서도 중첩 가상화를 추가 비용 없이 지원합니다. 다만 안쪽 하이퍼바이저는 KVM·Hyper-V만 지원하므로, 옮길 때는 VMware 없이 Ubuntu 위에 CAPEv2(KVM)를 바로 올립니다(AWS 사용자 가이드).

10.2 자체 구축 vs 클라우드 vs CDR 비교



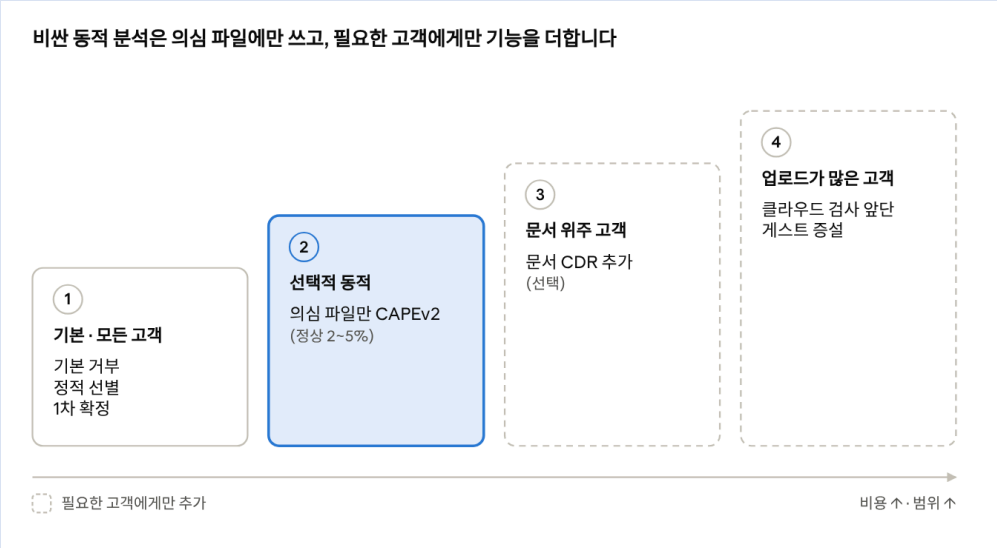
[그림 10-2] 세 가지 방식 비교

항목	자체 구축 (이 프로젝트)	클라우드 저장소 검사	CDR (무해화)
예	정적 분석 + CAPEv2	AWS GuardDuty S3, Microsoft Defender for Storage	OPSWAT Deep CDR, 소프트캠프 SHIELDEX, 지란지교시큐리티 SaniTOX
방식	형식별 추출 + 1차 확정 + 결합층 + 동적	엔진 정적 검사, 행동 분석 없음	파일을 다시 지어 위험 요소 제거, 판정 없음

항목	자체 구축 (이 프로젝트)	클라우드 저장소 검사	CDR (무해화)
한글 문서	자체 추출기	엔진 수준	OPSWAT·SHIELDEX가 지원 명시
실행·설치 파일	검사 가능	검사 가능	대상 아님(파일을 바꾸면 배포 불가)
비용 구조	장비·라이선스 + 운영 인력	GuardDuty $0.09/GB + $0.215/1,000개, Defender 저장소 계정당 시간 $0.0134 + $0.15/GB	공개 정가 없음(견적제)
판정 근거	파일별 전부 기록	결과 태그와 사유	제거한 요소 목록
운영 부담	높음(게스트·규칙 관리)	낮음	중간

- 가격 출처: AWS GuardDuty 가격(미국 동부), Azure 소매 가격 API(미국 동부). Joe Sandbox·VMRay는 견적제입니다.
- **예시 계산:** 하루 1만 개, 평균 1MB면 한 달에 약 300GB·30만 개입니다. GuardDuty는 약 $91.5(300GB × $0.09 + 300 × $0.215), Defender는 약 $55(저장소 계정 1개 약 $9.8 + 300GB × $0.15)입니다. 두 상품 모두 행동 분석과 한글 문서 전용 분석은 하지 않습니다.

10.3 소규모 조직 권장 전략



[그림 10-3] 소규모 조직 권장 전략 4단계

1. **기본 (모든 고객):** 기본 거부 + 정적 선별 + 1차 확정. ClamAV·YARA·LightGBM은 공개 도구라 라이선스 비용이 없습니다.
2. **선택적 동적 분석:** 의심 파일만 CAPEv2로 보냅니다. 게스트 한 대로 하루 약 330건.
3. **문서 위주 고객:** 원하는 고객만 문서에 CDR을 더합니다. 스피디의 파트너인 지란지교시큐리티가 문서 보안 제품을 갖고 있습니다. 실행·설치 파일은 CDR 대상이 아닙니다.
4. **업로드가 많은 고객:** 클라우드 저장소 검사를 앞단에 두어 알려진 악성을 싸게 걸러 내고, 게스트를 늘립니다.

핵심은 비싼 동적 분석을 의심 파일에만 쓰는 것이고, 이것이 정상 전송률 2~5% 기준의 이유입니다.

11. 실 서비스 적용 및 대응 방안

실제 서비스에서는 판정이 저장소 태그와 CDN 배포를 직접 제어하고, 오탐을 바로잡는 절차가 함께 있어야 합니다.

11.1 S3 태그·CDN 연동

- **배포 통제:** 저장소 정책으로 CLEAN 태그가 없는 파일의 내려받기를 막고, CDN 원본은 public/만 바라봅니다.
- **판정 반영:** worker의 판정에 따라 gateway가 태그를 붙이고 파일을 public/ 또는 quarantine/으로 옮깁니다(8절 매핑 표).
- **배포 뒤 악성 판정:** 재검사에서 악성으로 바뀐 파일은 CDN 캐시를 지우는 퍼지(Purge)를 요청합니다. 스피디 S-CDN은 퍼지 API를 제공합니다.
- **NHN Cloud에 적용할 때:** 객체 태그·이벤트 알림을 문서에서 찾지 못해, 폴더 구분 + DB 상태값으로 대신하고 업로드 API가 대기열에 직접 넣습니다.
- 프로젝트는 스피디의 실제 API를 쓸 수 없어 AWS S3·SQS로 구현하고, 퍼지는 호출 자리와 기록까지만 만듭니다.

11.2 운영 정책 (차단 / 격리 / 오탐 복구)

상황	정책	처리
1차 확정 차단	quarantine/에 격리 보관, 해시와 근거 기록, 업로드한 사람과 관리자에게 알림. 삭제 시점은 결정 항목	자동
동적 악성 확인	차단. 이미 배포됐으면 퍼지. 해시와 닮음 값을 1차 목록에 추가	자동
보류	관리자 확인 전까지 배포하지 않음. 업로드한 사람에게 사유 안내	관리자
오탐 신고 (정상인데 막힘)	관리자가 근거를 확인해 사용 가능으로 복구, 해시를 허용 목록에 추가, 오탐을 낸 규칙은 단서로 내림	관리자
재검사	시그니처·규칙·모델이 바뀔 때 '사용 가능' 파일을 다시 검사하고, 악성이면 퍼지	자동
감사 기록	판정을 바꾼 사람·시각·이유를 모두 기록	자동

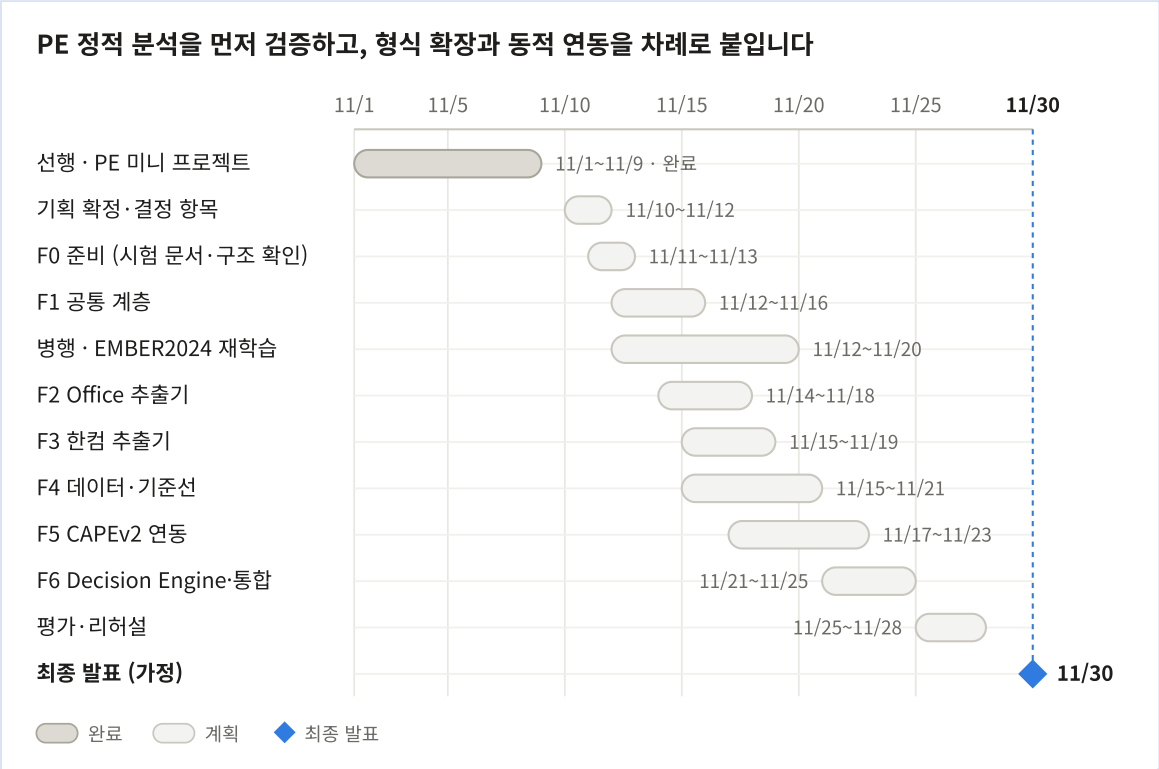
11.3 기대 효과 및 비즈니스 파급력

대상	기대 효과	근거
최종 사용자	검사를 통과한 파일만 받음	기본 거부 구조
최종 고객 (공공·교육·게임)	보안 장비 없이 한글·Office·실행 파일 검사. 사람은 보류 파일만 확인	자동 판정과 보류 사유 코드
스피디	CDN에 붙이는 보안 부가 서비스, 문서 위주 고객에게는 파트너 CDR 연계	10절 권장 전략
운영 비용	동적 분석을 의심 파일에만 써 게스트 사용 시간을 전부 실행할 때의 약 20분의 1~50분의 1로	정상 전송률 2~5% (계산값)
확장성	새 형식은 추출기만 추가, 이후 클라우드 중첩 가상화로 이전 가능	5절 ③ 형식별 추출, 10절

효과 수치는 미니 프로젝트 결과와 계산에서 나온 추정이고, 실제 고객 데이터로 다시 확인해야 합니다.

12. 추진 일정 (11/1 ~ 11/30)

11월 1일부터 9일까지는 선행 단계로 PE 정적 분석(미니 프로젝트)을 만들어 검증했습니다. 이어서 공통 계층을 먼저 만들고, 형식별 추출기와 데이터를 병행한 뒤, 동적 연동과 통합을 마지막에 붙입니다. 11월 10일 이후 날짜는 예시이고 역할 분담과 함께 확정합니다.



[그림 12-1] 추진 일정 · 11/1~11/30

기간	단계	완료 기준
11/1 ~ 11/9	선행 단계: PE 정적 분석 미니 프로젝트. 작업 VM의 Docker 환경, 1차 확정 검사, LightGBM, 결합층, 관리자 화면 구현·검증	완료: 시험 구간 평가와 결과 발표
11/10 ~ 11/12	기획 확정: 비PE 형식 분석 기법 조사, 기획서 작성, 결정 항목 10건	결정 항목에 답이 달림
11/11 ~ 11/13	F0 준비: 시험 문서 제작, 한셀·한쇼 구조 확인, 격리 VM의 vmx 확인	시험 문서 묶음, 중첩 가상화 동작
11/12 ~ 11/16	F1 공통 계층: 형식 식별, 재귀·한도, 보류 사유 코드	PE는 미니 프로젝트와 같은 결과, 암호 zip은 사유와 함께 보류
11/12 ~ 11/20	병행: EMBER2024로 LightGBM 재학습	미니 프로젝트 모델과 수치 비교
11/14 ~ 11/18	F2 Office 추출기	시험 문서가 해당 징후 가족을 켬
11/15 ~ 11/19	F3 한컴 추출기	내장 파일과 링크 대상을 꺼냄
11/15 ~ 11/21	F4 데이터 수집과 기준선	형식별 정상 전송률 표

기간	단계	완료 기준
11/17 ~ 11/23	F5 CAPEv2 연동: 게스트 설정, hwp 패키지, 행동 규칙	무해한 매크로 문서가 실행되고 규칙에 걸림
11/21 ~ 11/25	F6 Decision Engine과 통합: gateway 컨테이너 (S3·SQS·CAPEv2 연결), 태그·폴더·알림	시연 묶음으로 전 경로 확인
11/25 ~ 11/28	평가와 리허설	형식별 평가표, 발표 자료
11/30	최종 발표 (가정)	시연

13. 리스크 및 한계

가장 큰 리스크는 중첩 가상화 위의 CAPEv2가 우리 환경에서 제대로 도는지와, 한글 문서의 동적 분석이 사용자 동작 없이는 재현되지 않는다는 점입니다.

리스크	영향	대응
VMware 안에서 KVM을 돌리는 중첩 가상화가 느리거나 동작하지 않음	동적 분석 지연·불가	F0 준비 단계(11/11~11/13)에서 vmx 확인과 처리 시간 측정. 안 되면 EC2 중첩 가상화(KVM) 검토
CAPEv2의 hwp 패키지 미동작	한글 문서 자체를 열 수 없음	내장 파일 실행으로 대체하고 자체 패키지 작성. 한글은 정적 규칙을 주 탐지로
사용자 동작이 필요한 공격(링크 클릭·경고 수락)	동적에서 행동 없음	신뢰도 게이트로 보류, 강한 정적 증거는 낮추지 않음
문서 라벨 데이터 부족	무게·기준선이 부정확	계단 점수로 시작, 데이터가 쌓이면 다시 추정
데이터 약관 (MalwareBazaar 등)	학습 데이터 제약	평가에만 사용. 학습은 EMBER2024(Apache-2.0)와 연구 공개 데이터
Windows 10·Office 2016·2019 지원 종료(2025-10)	게스트 라이선스·구성	인터넷이 끊긴 분석 전용으로만 사용, 라이선스 확인
정상 파일 오탐 (업무용 매크로, 관리 도구)	고객 불편	매크로 있음은 징후가 아님, 오탐 복구와 허용 목록
AI 변종·패킹 같은 회피	정적·동적 모두 놓칠 수 있음	재검사(소급), 목록 갱신, 행동 규칙 보강
게스트 처리 용량	대기열 지연	강한 증거 파일 우선, 필요하면 게스트 증설
짧은 일정(11/1~11/30)	범위 미완	PE 정적 분석은 선행 단계(11/1~11/9)에서 완료. 1순위 형식 먼저, 한셀·한쇼·zip은 남는 시간에

한계: 시연 규모의 구현이고, 스피디의 실제 API와는 연동하지 않습니다. 성능 수치는 미니 프로젝트와 공개 연구에서 가져온 것이고, CAPEv2 관련 내용은 소스를 읽은 결과라 실측이 남아 있습니다.

14. 결정 필요 항목

아래 열 가지는 제안값을 적어 두었고, 확정은 팀이 합니다.

No	항목	선택지와 제안
1	**1순위 범위**	PE + MS Office + HWP·HWPX (제안)
2	**1차 확정 파일 처리**	즉시 삭제 vs 격리 보관 → 제안: 격리 보관 후 일정 기간 뒤 삭제(오탐 복구 가능)
3	**분석기가 없는 형식**	제안: 영상·이미지는 1차 통과 시 사용 가능, 실행형·스크립트는 보류
4	**재귀 한도 초깃값**	깊이 5, 300개, 300MB, 60초 (제안)
5	**malscore 기준**	7 이상 차단, 4~7 보류 (제안)
6	**게스트 소프트웨어**	MS Office 버전(CAPEv2 문서는 2010 SP2 또는 2016 32비트 권장)과 한컴오피스 버전·라이선스
7	**데이터셋**	9절 예시안으로 확정할지
8	**암호 문서**	보류 vs 올린 사람에게 암호를 받음 → 제안: 보류
9	**화면·저장소 구조**	FastAPI + React 신규 개발 vs 미니 프로젝트 화면(Streamlit) 재사용 → 제안: 시연은 미니 프로젝트 화면 재사용
10	**역할 분담과 일정**	12절 일정 확정

15. 부록

15.1 용어

용어	뜻
미니 프로젝트	본 과제의 선행 단계(11/1~11/9)로 PE 정적 분석(1차 확정 검사, LightGBM, 결합층)을 구현하고 검증한 프로젝트. 작업 VM의 Docker 환경도 이때 구성
Docker · Docker Compose	프로그램을 서로 격리된 컨테이너로 나눠 실행하는 도구. Compose는 여러 컨테이너와 네트워크를 설정 파일 하나로 함께 띄움
PE	Windows 실행 파일 형식(exe·dll)
복합 파일 (OLE·CFB)	파일 안에 여러 스트림을 담는 형식. doc·xls·ppt와 HWP 5.x가 사용
OOXML	ZIP 안에 XML을 담는 Office 형식(docx·xlsx·pptx 등)
HWP · HWPX	한글 문서. HWP는 복합 파일, HWPX는 ZIP과 XML
매직 바이트	파일 앞부분에 있는 형식 표시(예: 실행 파일의 MZ)
ClamAV	공개 백신 엔진
YARA	문자열·바이트 패턴으로 파일을 찾는 규칙 언어. YARA Forge는 공개 규칙 모음
TLSH · ImpHash	비슷한 파일을 찾는 지문
LightGBM	결정 나무를 여러 개 묶은 머신러닝 모델
로그 우도비	징후가 악성에서 정상보다 몇 배 자주 나오는지를 점수로 바꾼 값
정상 전송률	정상 파일 중 동적 분석으로 보내는 비율. 기준선을 정하는 기준
CAPEv2	공개 샌드박스. 격리된 가상 PC에서 파일을 실행해 행동을 기록
패키지	CAPEv2가 파일을 여는 방법(어떤 프로그램으로 어떻게)
malscore	CAPEv2가 서명으로 계산하는 0~10점 악성 점수
INetSim	실제 인터넷 대신 가짜 응답을 주는 도구
CDR	파일을 다시 지어 위험 요소를 없애는 무해화 기술
Presigned URL	짧게 만료되는 업로드 전용 주소
퍼지 (Purge)	CDN 캐시에서 파일을 지우는 요청

15.2 참고 자료

- 미니 프로젝트 저장소: malware-mini https://github.com/YoonJoony/malware-mini
- 공개 분석 플랫폼: Assemblyline 4, Strelka
- 도구: oletools, CAPEv2, CAPEv2 문서, ClamAV 문서
- 한글 문서 규격: HWP 5.0 명세, 한컴테크 HWPX
- 가격·수명 주기: AWS GuardDuty 가격, Windows 10 수명 주기, AWS 중첩 가상화
- 데이터: EMBER2024, Koutsokostas 외 (Zenodo), abuse.ch 이용 약관